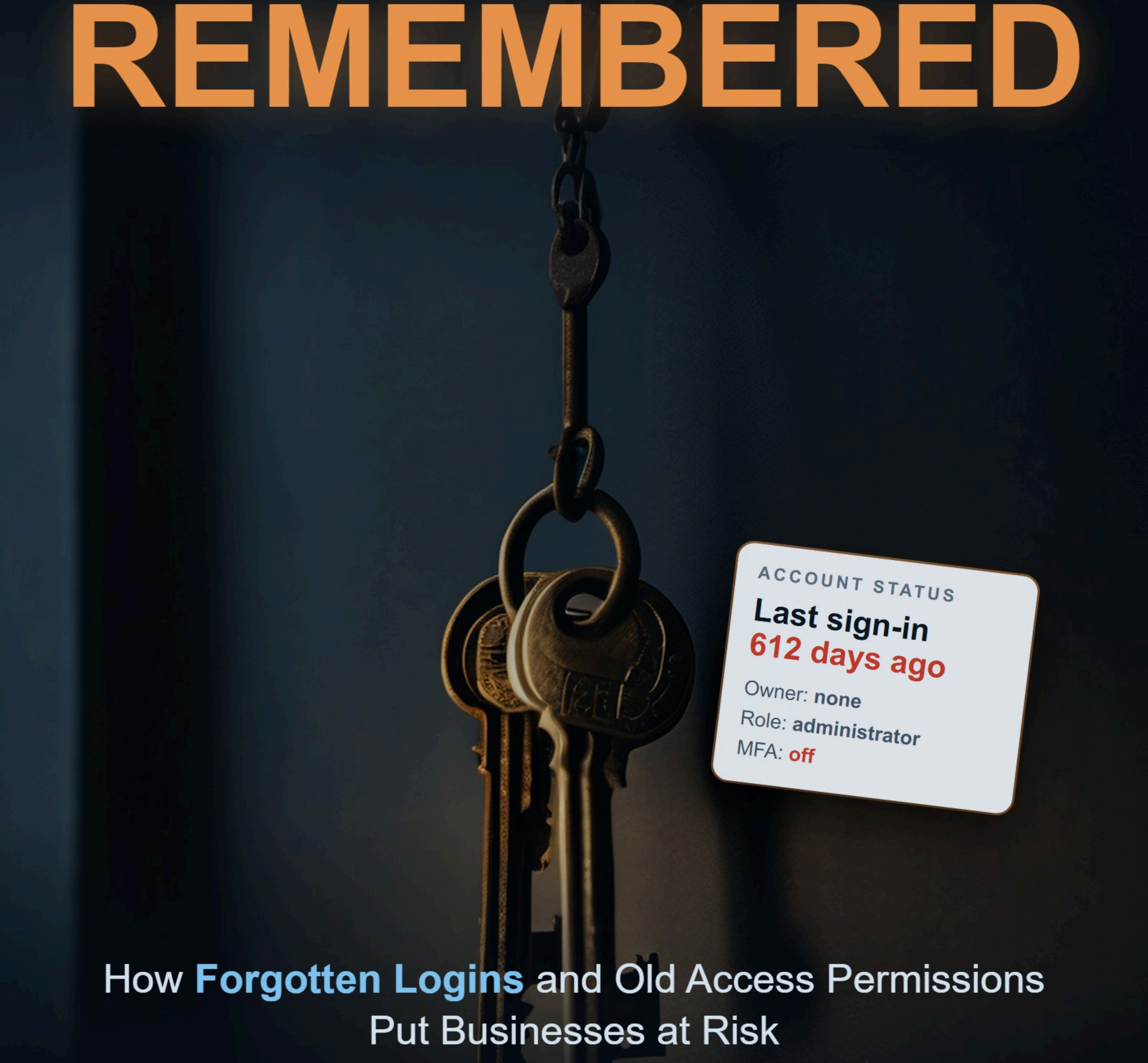
A SMALL-BUSINESS SECURITY GUIDE

THE ACCOUNT NOBODY REMEMBERED



How **Forgotten Logins** and Old Access Permissions Put Businesses at Risk

FORMER EMPLOYEES | ADMIN ACCESS | CLOUD ACCOUNTS | OFFBOARDING & REVIEWS

ZIRLANDIA MILKOVIC

A SMALL-BUSINESS SECURITY GUIDE

THE ACCOUNT NOBODY REMEMBERED

How Forgotten Logins and Old Access Permissions Put Businesses at Risk

ZIRLANDIA MILKOVIC

The Account Nobody Remembered

How Forgotten Logins and Old Access Permissions Put Businesses at Risk

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 9 November 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Login Nobody Closed 4
Who This Book Is For 5
How to Use This Book 6
The Five-Minute Forgotten Account Check 6

CHAPTERS

1. The Ghost in the Directory 8
2. Where Forgotten Access Hides 11
3. Former Employees' Accounts 14
4. Unused Administrator Access 17
5. Forgotten Cloud Accounts 21
6. How Attackers Find and Use Them 24
7. The Business and Legal Cost 27
8. Offboarding That Actually Works 30
9. Access Reviews Step by Step 34
10. Taming Admin and Cloud Access 37
11. If a Forgotten Account Is Already Being Used 40
12. Your 30-Day Clean-Up Plan 44

CLOSING

Conclusion: Close the Door 47

APPENDICES

Appendix A: The Offboarding Checklist 48
Appendix B: Account Inventory Template 50
Appendix C: Access Review Worksheet 51
Appendix D: Admin and Cloud Audit Checklist 52
Appendix E: One-Page Access Policy Template 53

BACK MATTER

Glossary 54
A Note on GDPRGard.eu 55
About the Author 56
Notes and Sources 57

Educational Disclaimer

This book is practical, educational guidance for small-business owners, managers, office administrators and the people who support them. It is not legal, insurance or professional security advice, and it does not create a professional relationship between the author and the reader.

Software, cloud services and regulations change quickly. Menu names, settings and licence tiers differ between products and move over time. Check current guidance from your national cyber-security agency, your data-protection authority, your IT provider or your insurer before relying on anything here for a decision that matters.

Following the steps in this book can reduce your risk. It cannot remove it. If you believe an account has already been misused, treat it as an incident, preserve evidence and ask a qualified professional to help.

Every person, business and story in a worked example is **fictional** and labelled as such. Real incidents are sourced in the notes at the back.

Introduction: The Login Nobody Closed

Somewhere in your business there is an account that nobody remembers.

It might belong to a designer who left two years ago. It might be the administrator login that a former IT contractor set up and never handed over. It might be a cloud subscription someone started for a one-week experiment, or a free trial that quietly turned into a live system. It still works. It still has a password. It might have access to customer data, to your bank's portal or to the settings of your whole company.

Nobody is using it, so nobody is watching it. That is exactly why it is dangerous.

Most security advice focuses on the front door: strong passwords, firewalls, training staff not to click. All of that matters. But attackers are practical. They look for the door that is easiest to open, and an unwatched account with a reused password and no second factor of authentication is about as easy as it gets. Several of the best-known breaches of recent years began this way, with an old, forgotten or poorly guarded account rather than a clever exploit.

This book is about closing those doors.

> **The rule.** Every account must have a living owner, a current reason to exist and the least access it needs. If it fails any of the three, it is a risk. Fix it or close it.

The book follows four threads that every small business meets sooner or later:

- **Former employees' accounts.** People leave. Their access often does not.
- **Unused administrator access.** Powerful accounts that nobody is accountable for.
- **Forgotten cloud accounts.** Subscriptions, tenants, storage and trials that outlive their purpose.
- **Access reviews and offboarding checklists.** The routines that stop all of the above from accumulating.

You do not need to be technical, and you do not need an IT department. You need a clear picture of where forgotten access hides, a short list of habits, and a calendar.

Who This Book Is For

This book is written for:

- **Business owners and managers** who suspect that "who can get into what" is not written down anywhere, and want to fix that without hiring a team.

- **Office managers and operations leads** who handle starters and leavers and are told to "sort out the IT" alongside everything else.
- **Part-time IT helpers and IT providers** who need a ready-made offboarding checklist and review process to hand to a client.
- **HR and finance staff** who are the first to know when someone leaves and the last to be asked about their accounts.
- **Freelancers and consultants** who work in many clients' systems and want to leave no loose ends behind.

A word on tone. Nothing here is meant to make you feel careless. Forgotten accounts are a natural by-product of a business that grows, changes tools and moves quickly. Every organisation that has been running for more than a year has some. The goal is to find them before somebody else does.

How to Use This Book

You can read the book start to finish in an evening, or jump to what you need.

- **In a hurry?** Read the introduction, then Chapter 8 (offboarding) and Appendix A (the offboarding checklist). Use it the next time someone leaves.
- **Want to know where you stand?** Do the five-minute check on the next page, then work through Chapter 12 (the 30-day clean-up plan).
- **Running a business?** Read Chapters 3 to 5, then use Appendices B and C to build your account inventory and run your first review.
- **Think an old account is already being misused?** Go straight to Chapter 11.

Each chapter ends with a short action list. The appendices are designed to be printed or copied into a spreadsheet.

The Five-Minute Forgotten Account Check

Answer yes or no. Be honest; nobody is marking this.

- ☐ I can name everyone who currently has administrator access to our email, our website, our domain registrar and our main cloud account.
- ☐ Every person who left in the last 12 months had all of their accounts closed on or before their last day.
- ☐ We have a written list of the software and cloud services the business pays for or uses, with an owner for each.
- ☐ Multi-factor authentication is switched on for every administrator and for all email accounts.
- ☐ Someone reviews who has access to what at least twice a year.
- ☐ We know of no shared logins whose password has not changed since someone left.
- ☐ No free trial or test system is running that nobody is responsible for.

Scoring. Seven yes answers: you are ahead of most businesses, and Chapter 9 will help you keep it that way. Four to six: normal, and fixable in a month. Three or fewer: you almost certainly have forgotten access right now. That is not a disaster. It is a to-do list.

CHAPTER 1

The Ghost in the Directory



> **Fictional.** Northgate Studio, Elena and Tomas are invented. The pattern is real and common.

Northgate Studio is a fourteen-person design agency. Elena, the founder, is proud of how tidy it is. Invoices go out on time. Files are organised. When Tomas, a senior designer, left in the spring, there was a cake and a card.

Eighteen months later, someone in Moldova logs into Tomas's old email account.

Nobody at Northgate notices at first. Tomas's mailbox was never deleted. It was never even switched off, because the licence was cheap and Elena thought a client might still write to him. The password was the one Tomas used on three other sites, and one of those had been breached the year before. There was no second factor. From that mailbox, the intruder searches for the words *invoice*, *bank* and *password reset*, and within two days has everything needed to send Northgate's clients a polite message: *our bank details have changed.*

This book is about accounts like Tomas's. We will call them **ghost accounts**: logins that still exist, still work, and have no active owner paying attention.

What a ghost account is

A ghost account is any login that meets three conditions:

1. **It still works.** It can sign in, or its keys and tokens can still be used.
2. **It has no accountable owner.** The person it belonged to has left, changed role or forgotten it.

3. **Nobody is watching it.** Its activity is not reviewed, so misuse looks like normal background noise.

They are not exotic. They are the ordinary leftovers of a business that has been running for a while.



A deserted desk with a dim screen still glowing

Why they are more dangerous than they look

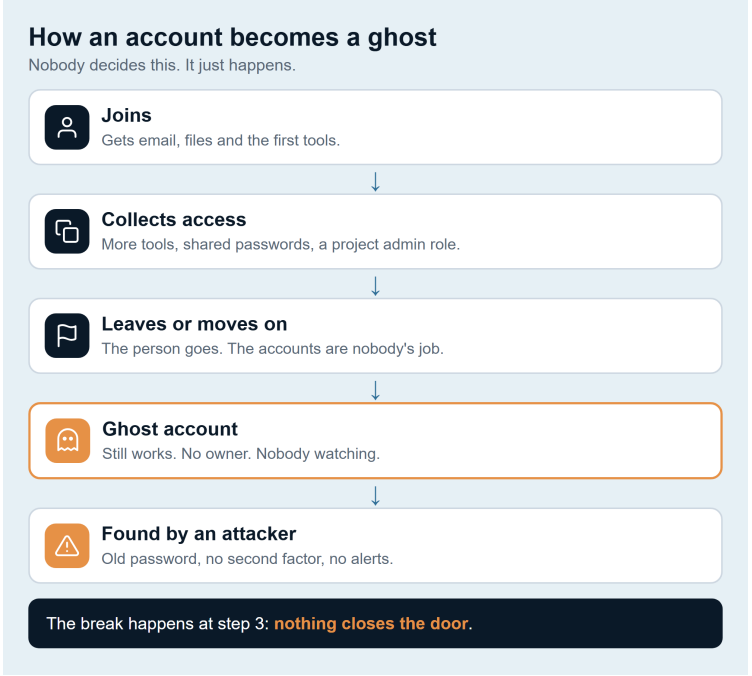
A live account has a person behind it. That person notices strange sign-in alerts, changes passwords when asked, complains when something stops working. A ghost account has none of that. The protections that rely on a human paying attention (alerts, password changes, "was this you?" emails) quietly stop working.

Three things make ghost accounts especially attractive:

- **They are quiet.** A burst of activity on an account that has been dormant for a year may not be anyone's job to notice.
- **They are old.** Old accounts tend to have old passwords, no second factor and permissions granted for a role the person no longer has.
- **They are trusted.** An action from a real employee account looks legitimate to systems and to colleagues alike.

The life of a ghost

Almost every ghost account follows the same path. A person starts and gets accounts. They collect more as projects come and go. Then they leave, or the project ends, and **the accounts do not follow them out.** Closing a door is nobody's job, because opening it was everybody's.



How an account becomes a ghost

What this book will do

By the end you will be able to:

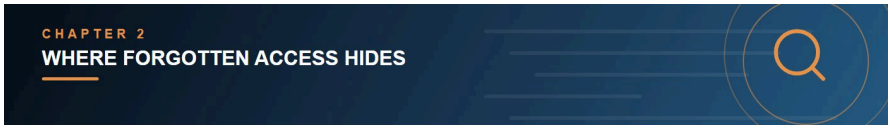
- Find the ghost accounts you already have.
- Stop new ones appearing, with an offboarding routine that takes minutes.
- Cut administrator access down to the people and purposes that genuinely need it.
- Keep cloud accounts and trials from drifting out of sight.
- Run a short access review twice a year that catches what slips through.

Action list

- ☐ Write down the last three people who left your business.
- ☐ For each, note whether you can say for certain that every account is closed.
- ☐ Keep that note. You will use it in Chapter 3.

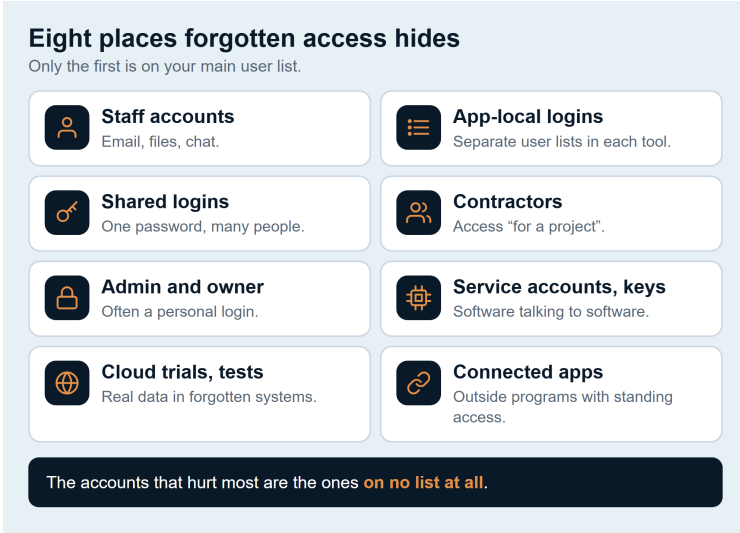
CHAPTER 2

Where Forgotten Access Hides



Before you can close forgotten access, you need to know where to look. Most businesses think of "accounts" as email and a couple of apps. In reality, access is scattered across at least eight places.

The eight hiding places



Eight places forgotten access hides

1. Staff user accounts. The obvious one: email, file storage, chat and the main business apps. These are the accounts a leaver was given on day one.

2. Local accounts inside apps. Many tools keep their own list of users, separate from your main email login. Closing someone's email does not touch these. Accounting packages, CRMs, design tools and e-commerce back-ends are common culprits.

3. Shared logins. One username and password used by several people: the social-media account, the supplier portal, the Wi-Fi router, the domain registrar. When one person leaves, the password they knew is still valid unless somebody changes it.

4. Contractor and agency accounts. Freelancers, accountants, marketers and web developers are given access "for a project". Projects end; access rarely does.

5. Administrator and owner accounts. The account that created your cloud subscription or domain registration is often a personal login of whoever set it up, sometimes an ex-employee or ex-supplier.

6. Service accounts, API keys and tokens. Not people at all: logins used by software to talk to other software. They usually never expire and are rarely listed anywhere.

7. Cloud trials and test systems. The environment somebody spun up to try something. It may hold a copy of real data.

8. Connected apps and permissions. When someone clicks "Sign in with Google" or "Allow this app to access your mailbox," they grant an outside program standing access. It stays even after the person leaves unless it is revoked.

Why you cannot just "look at the user list"

The main user list in your email system shows only the first category. Everything else lives in other places, under other administrators, sometimes under a personal login.

> **Insight.** The accounts that cause the most damage are rarely the ones in the central list. They are the ones that never appeared in any list at all.

Four questions that find forgotten access

For anything you discover, ask:

1. **Who owns it?** A named person who is still here and still responsible.
2. **Why does it exist?** A current business purpose, not a historic one.

3. **What can it reach?** Data, money, settings, other systems.
4. **When was it last used, and by whom?** Most platforms will tell you the last sign-in.

An account that cannot answer all four is a candidate for closing.

The sources of truth

Start your inventory from places that already record what you use, not from memory:

- **The finance trail.** Card statements and invoices show every paid service, including the forgotten ones.
- **The email trail.** Search the company mailbox for "welcome to", "confirm your email" and "your trial".
- **The admin consoles.** Your email platform lists users, groups, connected apps and last sign-in dates.
- **The domain and DNS records.** They reveal services connected to your website and email.
- **The people.** Ask each team: "Which tools do you use that I might not know about?"

Action list

- ☐ Open your card or bank statements for the last 12 months and highlight every software or online-service payment.
- ☐ Search the company mailbox for "welcome to" and "trial".
- ☐ Start the inventory in Appendix B with whatever you find.

CHAPTER 3

Former Employees' Accounts



When a colleague leaves, a quiet transfer of power happens. Until that moment they had a legitimate need to reach your systems. At the end of their last day, the need ends. Whether the access does too depends entirely on what you did.

Why offboarding fails

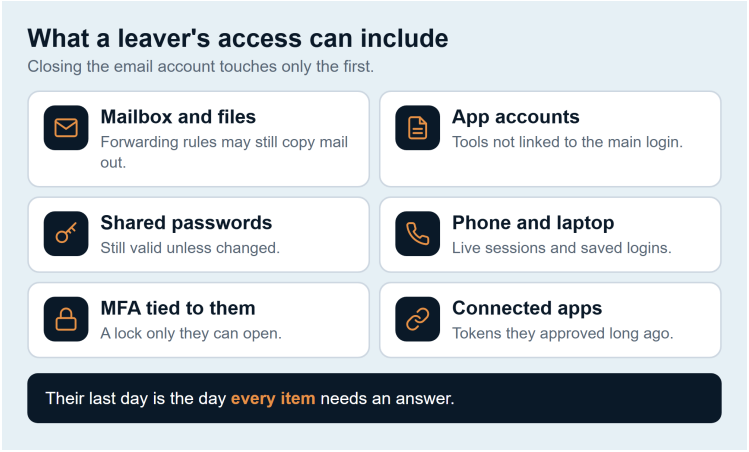
It is rarely carelessness. It is structure.

- **No single owner.** HR knows when someone leaves. IT knows how to switch things off. The manager knows what the person used. Nobody holds all three.
- **No complete list.** Even the person's manager rarely knows every tool they signed up for.
- **No trigger.** Leaving is a process spread over weeks, but the access removal is expected to happen "when somebody remembers."



A lanyard and access card left behind

What a leaver typically still has



What a leaver's access can include

Email and files. Their mailbox, their cloud storage and any documents shared with their personal address. Forwarding rules set up long ago may still copy messages to a private account.

Application accounts. Logins in tools that are not tied to the main directory.

Shared passwords they knew. Social media, supplier portals, the router, the alarm.

Their phone and laptop. Business email, a password manager session and saved logins on a device you may not control.

Multi-factor authentication tied to them. Their phone number or authenticator app is the second factor on accounts they still administer. That is a lock only they can open.

Connected apps. Programs they authorised to read mail, calendars or files.

Delete, disable or keep?

The safest first step is almost never deletion.

Option	When to use it	Watch out for
Disable sign-in	Day of departure, for every leaver	Does not stop forwarding rules or active sessions
Convert to shared mailbox	When colleagues need to keep receiving the person's mail	Needs an owner; set an end date
Delete	After the retention period and once data has been moved or exported	Deletion is often permanent; check legal retention first
Leave untouched	Never	This is how ghost accounts are born

The data-protection angle

A leaver's mailbox is full of personal data about customers, colleagues and suppliers. Under the GDPR, personal data must be kept secure and not kept longer than needed [1]. A mailbox kept open "just in case" for years is difficult to defend on either count. Decide, write down how long you keep a leaver's data, and then follow through.

The ex-employee who does not mean harm

Most former employees are not malicious. The risk is rarely a revenge attack. It is more mundane:

- Their credentials are reused elsewhere and get stolen.
- Their personal device is lost or infected while still holding a live session.
- They log in out of habit to "grab something they left behind," which still counts as unauthorised access.
- A colleague asks them for help and they log in as a favour.

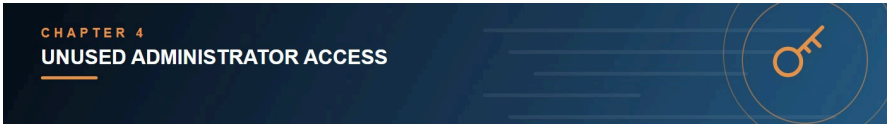
The remedy is the same in each case: **no access after the last day, unless a new, documented arrangement says otherwise.**

Action list

- ☐ Return to the three leavers you listed in Chapter 1.
- ☐ For each, check mailbox, forwarding rules, connected apps and shared passwords, then disable anything still open.

CHAPTER 4

Unused Administrator Access



> **Fictional.** Harbour Print, Ines and the contractor "Dev" are invented.

Ines runs Harbour Print, a small online printing shop. Four years ago a freelance developer, whom we will call Dev, built her website. To do it, Dev needed full control, so Ines created an administrator account for him. The project finished, Dev moved on, and the account stayed.

Last year the shop's website was defaced and customer orders were exposed. The way in was Dev's account. His email address had been in a breach, and his password was the same one he had used on the shop.

Administrator access is the most valuable thing in your business. It is also the thing most likely to be left lying around.

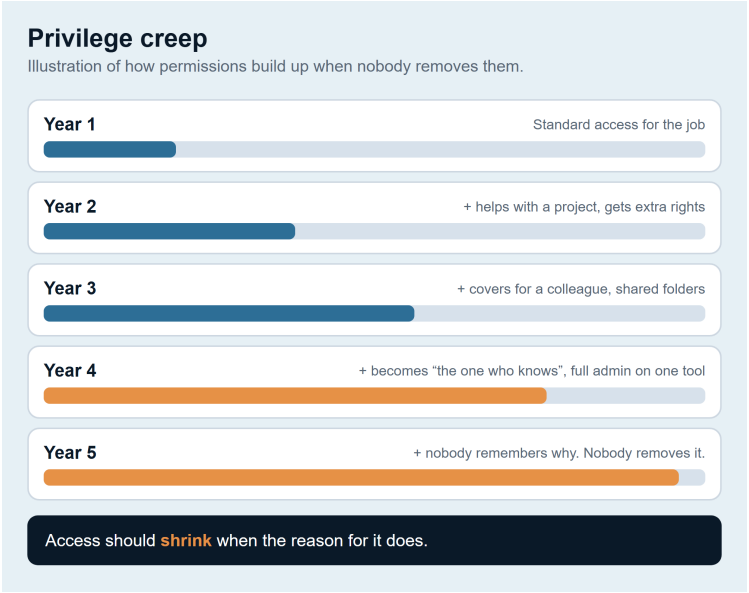
Why admin accounts are different

A normal account can reach what its owner needs. An administrator account can usually:

- Create, change and delete other accounts.
- Read or change everyone's data.
- Switch off security settings, logs and alerts.
- Add new ways in that survive a password reset.

So a compromised administrator login is not one problem. It is the key to every other problem, and a good way to hide the damage afterwards.

How admin access piles up



Privilege creep, one extra permission at a time

Privilege creep. Someone helps with a project and is given extra rights. The project ends. The rights stay. After five years, an office manager can change company bank details and nobody remembers why.

The founder effect. In small firms the first person to set something up becomes its permanent owner. Years later they run the business on a personal login with full rights.

The "just give me admin" shortcut. It is faster to grant full rights than to work out which narrow right is needed.

Departed owners. The account that created the domain, the cloud subscription or the social media page may belong to an ex-employee or an ex-agency. If they vanish, you may not be able to recover your own assets.



Tangled keys and cards, none of them labelled

The principle of least privilege

Give every person and every system the **minimum access needed to do their job, for as long as they need it, and no longer.**

Practical rules:

1. **Few administrators.** For most small businesses, two or three named people is enough. Two, not one, so there is a backup.
2. **Separate admin and everyday accounts.** The person who administers the system should read their email on a normal, non-admin login. If phishing catches the everyday account, the damage is limited.
3. **Role, not person.** Give admin rights as a role that can be taken away, not by sharing the founder's login.
4. **Time-limited when possible.** For occasional tasks, grant admin rights for a day and remove them.
5. **A break-glass account.** One emergency administrator account, with a very long password stored offline and a clear note saying when it may be used. Check that it still works, and alert yourself if it is ever used.

Finding unused admin access

Look for:

- Administrator accounts that have not signed in for 90 days.
- Admin accounts with no second factor.
- Admin rights held by people who have changed role or left.

- Third-party admins (developers, agencies, accountants) with ongoing, unlimited access.
- Admin accounts in systems that are not your main platform: website, domain, DNS, payment processor, social media, backup tools.

For each, apply a simple test: **if this account were misused tomorrow, would we notice, and could we recover?** If the answer to either is no, act.

The last administrator

One more trap: the lone administrator leaves, and nobody else can reset anything. Always keep at least two people able to manage each critical system, and record who they are.

Action list

- ☐ List every administrator on your email platform, domain registrar, website and payment tools.
- ☐ Remove admin rights from anyone who does not actively need them.
- ☐ Switch on multi-factor authentication for every remaining administrator.
- ☐ Set up and test one break-glass account.

CHAPTER 5

Forgotten Cloud Accounts



> **Fictional.** Fernwood Analytics and Kofi are invented.

Fernwood Analytics is a small consultancy. In a quiet week, Kofi, an analyst, spins up a cloud database to test a reporting idea. To make the test realistic he loads a copy of a real client spreadsheet. The idea goes nowhere. Kofi moves to another project, and later leaves the company.

The database is still running. It costs a few pounds a month. Nobody sees the charge because it is lost among larger ones. It has a default setting that lets anyone with the address connect, and a password Kofi chose in a hurry.

Cloud services make it easy to start things and invisible to stop them.

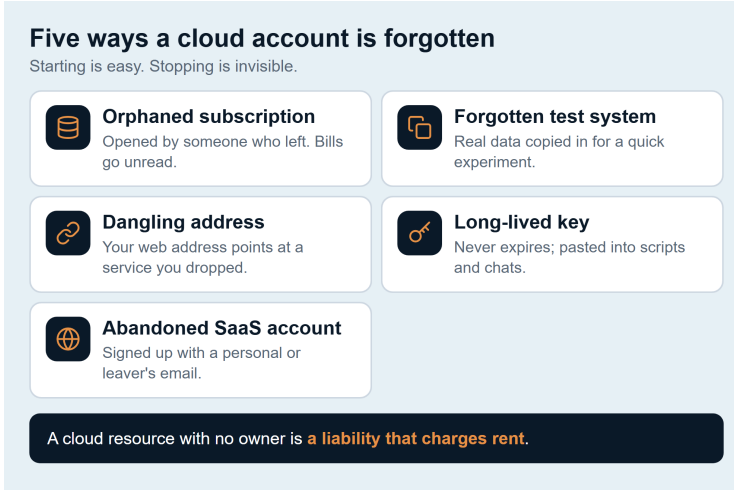
Why the cloud multiplies the problem

- **Anyone with a card can start a service.** There is no purchase order, so no one in the business may know.
- **Free trials convert quietly.** A trial that needed a card number can become a paid, live system.
- **Resources are separate from people.** Closing a person's account does not stop the things they created.
- **Costs are small, so unnoticed.** A forgotten server rarely shows up as a spike.
- **Defaults are generous.** Convenience settings can leave storage or databases open to the internet.



A dark server room with one rack still lit

The forgotten cloud in five forms



Five ways a cloud account is forgotten

1. The orphaned subscription. An entire account, tenant or workspace opened by someone who has since gone. Billing goes to a card, or an email address, that nobody reads.

2. The forgotten test system. Servers, databases and storage created for an experiment, often with real data copied in.

3. The dangling address. A website address that still points at a cloud service you stopped using. An attacker can sometimes register that service and take over your address. This is called a **subdomain takeover**, and it can be used to host convincing fake pages under your own name.

4. The long-lived key. A password-like secret used by software (an API key or access token). It may have been pasted into a script, shared in chat or committed to a code repository, and it never expires.

5. The abandoned SaaS account. A tool signed up for with a personal or leaver's email, holding customer data nobody exports or deletes.

What to do

Know your accounts at the top level. For each cloud platform you use, confirm: who is the owner, what is the billing contact, where do alerts go, and who can recover the account if the owner is gone? Use a role address such as `cloud-admin@yourcompany.example`, not a personal one.

Make everything have a label. Require a name, an owner and an end date on every resource. If it has none, it is a candidate for removal.

Set budgets and alerts. Every major platform lets you set a monthly spending alert. A forgotten server often reveals itself that way.

Turn on the default protections. Multi-factor authentication on every human account, and on the root or owner account first. Block public access to storage unless it is genuinely meant to be public.

Review monthly. Look at the list of running resources and ask of each: "Do we still need this?" Deleting a test system is a ten-minute job that removes a permanent risk.

Clean up addresses. Review your DNS records twice a year. Remove any that point to services you no longer use.

> **Insight.** A cloud resource without an owner is a liability that charges you rent.

Action list

- ☐ Find every cloud platform and SaaS tool in your finance trail.
- ☐ Confirm an owner, a role-based billing email and MFA for each.
- ☐ Set a monthly spend alert.
- ☐ Delete or shut down anything nobody can justify.

CHAPTER 6

How Attackers Find and Use Them



Attackers are not looking for your company specifically. Most are looking for any door that opens. Understanding how they test the doors shows why ghost accounts rank so high.

Step one: get a list of valid logins

Valid usernames are not secret. Staff email addresses are on websites, in signatures and in earlier breaches. Credentials are also sold: **infostealer malware** infects a person's computer, collects saved passwords and sessions, and the results are traded in bulk. A password stolen from a leaver's home computer three years ago may still be for sale and still work.

Step two: try them everywhere

Two methods dominate:

- **Credential stuffing.** Take passwords leaked from one site and try them on others. It works because people reuse passwords.
- **Password spraying.** Try a few very common passwords against many accounts, slowly enough to avoid lockouts.

Both are automated. A ghost account with a reused or weak password and no second factor will eventually fall to one of them.

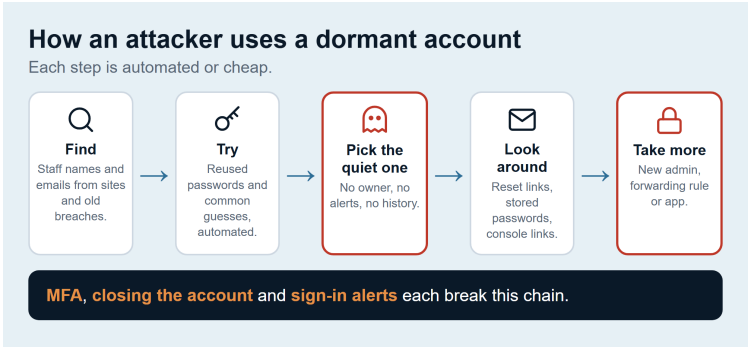
Step three: choose the account nobody watches

Once inside, attackers prefer accounts where nobody will notice:

- No owner to see a "new sign-in" alert.
- A history of no activity, so any change is lost in silence.

- Left-over permissions that are broader than anyone remembers.

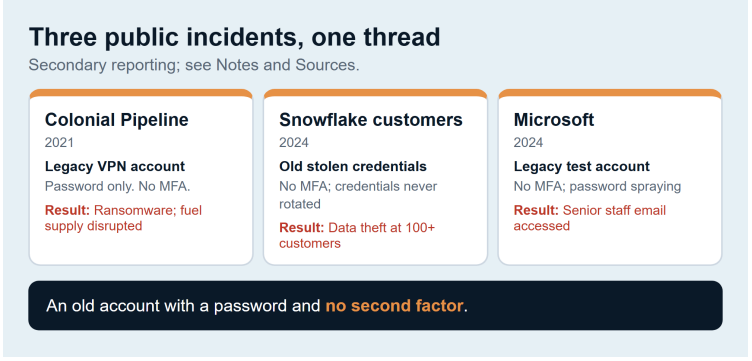
From that foothold, they look for more: a reset email, a stored password, a link to a cloud console, a way to create their own administrator account.



How an attacker moves through a dormant account

Three real cases

These are widely reported incidents. They involve very large organisations, but the weakness is the same one found in small ones.



Three public incidents with a common thread

Colonial Pipeline, 2021. The company's chief executive told a US Senate committee that the ransomware attack began with a compromised virtual private network (VPN) account. It was a legacy account protected by a password alone, with no multi-factor authentication. The company said it did not know how the attackers obtained the password [2].

Snowflake customers, 2024. Mandiant reported that attackers used stolen credentials to reach data in over a hundred customer environments of a cloud data platform. The credentials mostly came from earlier infostealer infections, some dating back to 2020, and had never been changed. The affected accounts did not have multi-factor authentication switched on. Mandiant found no flaw in the platform itself [3].

Microsoft, 2024. Microsoft disclosed that a Russian state-linked group had used password spraying to compromise a legacy test account that did not have multi-factor authentication. The group then used the account's permissions, including those of an old test application, to reach the email of senior staff [4].

The common thread is plain: **an old, rarely watched account, with a password but no second factor, was the way in.** None of these relied on a brilliant exploit.

What this means for you

Large organisations have security teams and still fall to this. A small business is no safer for being small. Automated attacks do not care about size. They care about opportunity.

The same three controls break the chain at almost every step:

1. **Multi-factor authentication** makes a stolen password insufficient.
2. **Closing unused accounts** removes the target.
3. **Monitoring sign-ins** turns silent misuse into a visible alert.

Action list

- ☐ Check your platform for accounts that have never had MFA.
- ☐ Turn on sign-in alerts for administrators and for any sign-in from a new country.
- ☐ Search a breach-notification service for your business email domain.

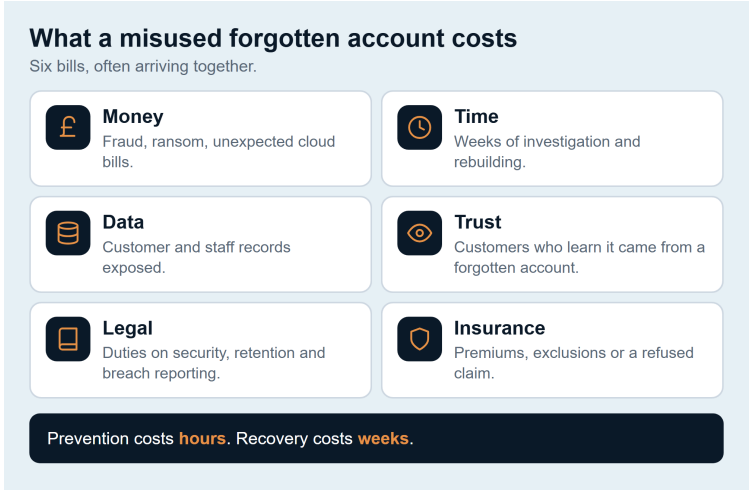
CHAPTER 7

The Business and Legal Cost



A forgotten account is not a theoretical weakness. When it is used, the bill arrives in several currencies at once.

The direct costs



The cost categories when a forgotten account is misused

- **Money.** Fraudulent invoices, redirected payments, ransom demands, unauthorised cloud usage.
- **Time.** Investigating what was reached, resetting everything, rebuilding trust. For a small team, weeks of distraction.
- **Data.** Customer, staff and supplier information copied or exposed.
- **Reputation.** Customers who learn their data was taken through an account you forgot to close are rarely sympathetic.

- **Insurance.** Cyber-insurance applications now routinely ask about multi-factor authentication, offboarding and access reviews. A gap can raise the price or void a claim.

Where the GDPR comes in

If your business handles personal data of people in the EU or UK, access control is a legal duty, not only good practice. In plain terms, the GDPR expects you to:

- **Keep personal data secure**, using appropriate technical and organisational measures (Article 5(1)(f) and Article 32) [1].
- **Limit access to those who need it** and take steps so that people with access act only on instruction (Article 32(4)).
- **Not keep data longer than necessary** (Article 5(1)(e)). A dormant mailbox or test database full of personal data is hard to justify.
- **Build data protection into your systems and processes** from the start (Article 25).
- **Report certain breaches** to the supervisory authority within 72 hours of becoming aware, and tell affected people when the risk to them is high (Articles 33 and 34) [5].



A filing cabinet left open in a dim office

A regulator who investigates a breach through a ghost account will ask questions like these:

- Did you have a process for removing access when staff left?
- Did you review who had access, and when?
- Was multi-factor authentication in place for privileged accounts?
- How long did the account sit unused?

"We forgot" is an honest answer. It is not a good one. Written procedures and dated review records are your best evidence that you took reasonable care.

Wider rules that point the same way

- **NIS2** and similar national rules bring access control, multi-factor authentication and supply-chain security into scope for many medium and larger organisations in the EU. Whether you are covered depends on your sector and size; check with your national authority [6].
- **Customer contracts** and security questionnaires increasingly require proof of offboarding and access reviews.
- **Unauthorised access by a former employee** can be a criminal offence in most countries, but you cannot rely on that if you left the door open and never recorded that access had ended.

The cost of prevention

Everything in the next chapters costs very little: an afternoon to build an inventory, fifteen minutes per leaver, half a day twice a year for a review. Set that against a single incident and the comparison makes itself.

> **The rule.** A task that takes fifteen minutes when someone leaves takes fifteen weeks when it goes wrong.

Action list

- ☐ Note who in your business is responsible for GDPR security decisions.
- ☐ Write down how long you keep a leaver's mailbox and files.
- ☐ Check what your cyber-insurance application says about MFA and offboarding.

CHAPTER 8

Offboarding That Actually Works

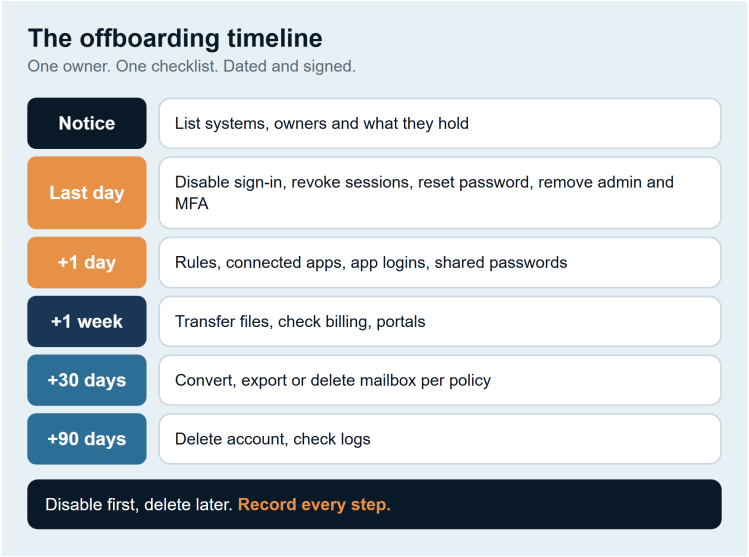


Offboarding is the single most effective habit in this book. It is also the easiest to build, because the trigger, someone leaving, is a clear event.

Five principles

1. **One owner.** A named person is accountable for completing the checklist. Not "HR and IT".
2. **Start before the last day.** The process begins at the moment notice is given, not on departure.
3. **The checklist is a record.** It is signed and dated, and it is your proof later.
4. **Timing is part of the control.** Sign-in is disabled at the end of the last working day, or sooner for sensitive roles.
5. **Disable first, delete later.** You can always restore a disabled account. You cannot restore a deleted one.

The offboarding timeline



An offboarding timeline from notice to 90 days after

When notice is given

- Manager lists every system the person uses, including tools they signed up for themselves.
- Identify what they own: shared passwords, domains, subscriptions, admin roles, scheduled reports, customer relationships.
- Agree who inherits each item.

Last working day

- Collect devices, cards and keys.
- Disable sign-in to the main account at the agreed time.
- Revoke active sessions and sign the person out of all devices.
- Reset their password so that a saved session cannot be reused.
- Remove them from groups, shared folders and distribution lists.
- Remove or re-assign admin roles.
- Disable their multi-factor authentication methods and remove the device registration.

Within a day

- Check and remove mailbox forwarding rules and delegated access.
- Revoke connected apps and tokens they authorised.
- Disable their accounts in every separate application.
- **Change every shared password they knew.**
- Update the access list for the building, alarm and Wi-Fi.
- Set an automatic reply or redirect for their email, with an end date.

Within a week

- Move or export files and records the business needs.
- Confirm no business subscriptions run on their personal email or card.
- Remove the person from the supplier and customer portals.
- Complete and file the checklist.

At 30 and 90 days

- Confirm the mailbox is converted, exported or deleted according to your retention rule.
- Delete the disabled account once the retention period has passed.
- Check that no sign-in attempts to the old account appeared in the logs.

Special cases

Dismissals and difficult departures. Remove access before or at the moment the person is informed, and agree the sequence with HR. Speed matters more than politeness here.

Contractors and agencies. Give every contractor an end date when you create their account. Access should expire by itself unless renewed.

Role changes. A move to another team is a mini-offboarding. Remove access tied to the old role. Privilege creep begins here.

Owner and founder exits. The hardest one. Hand over ownership of the domain, the cloud account, the bank portal and the password manager before departure, not after.

Make it easy to follow

A checklist that lives in someone's head does not work. A checklist that takes three pages and a meeting does not work either. Appendix A gives a one-page version. Copy it, add your own tools, and keep the completed copies.

> **Insight.** The best offboarding system is one where the person doing it cannot skip a step because the form will not close.

Action list

- ☐ Print Appendix A and customise it with your own tools.
- ☐ Name the person accountable for each leaver.
- ☐ Add "access removed" to your HR leaving checklist.

CHAPTER 9

Access Reviews Step by Step



Offboarding catches people who leave. It does not catch everything else: contractors who finished, staff who changed role, trials that never ended, tools no one remembers adopting. That is the job of the **access review**.

An access review is simple. At regular intervals, the people who know the work look at the list of who can access what and confirm: *yes, still needed* or *no, remove*.

How often?

- **Administrator and privileged access:** every quarter.
- **All staff accounts and application access:** every six months.
- **Contractors and third parties:** at the end of each engagement, and every quarter while they run.
- **Cloud resources and subscriptions:** monthly glance, full review every six months.
- **After any big change:** a restructure, an acquisition, a security incident.

The review cycle



A five-step access review cycle

Step 1: Gather. Export the list of accounts and permissions from each system. Most admin consoles can produce a spreadsheet with user, role, last sign-in date and whether multi-factor authentication is on.

Step 2: Assign reviewers. The right reviewer is the person who knows whether the access is still needed: usually the line manager, not IT. IT supplies the data; managers make the decisions.

Step 3: Review. For every line, the reviewer chooses **keep**, **reduce** or **remove**, and writes why if it is not obvious. Flags worth special attention:

- No sign-in for 90 days or more.
- Admin or owner rights.
- No multi-factor authentication.
- Names that do not match a current person.
- External email domains.
- Generic or shared accounts.

Step 4: Act. Changes are made within a set deadline, say seven days. Whoever makes the change records the date.

Step 5: Record. Keep the reviewed spreadsheet, dated and initialled. Next time you will compare against it, and a regulator or insurer will be satisfied by it.

Using sign-in data wisely

"Last sign-in" is the most useful column in any review. But treat it carefully:

- An account with **no sign-in for months** is a strong candidate for removal.
- An account **used only by software** (a service account) may look dormant yet be doing important work. Do not delete it blindly; find its owner first.
- An account with a **sudden burst of activity after months of silence** deserves a look. Go to Chapter 11.

A review for a ten-person business

You do not need special software. Here is a realistic half-day:

1. Export the user list from your email platform (15 minutes).
2. Export the user lists from your three or four main apps (45 minutes).
3. Paste them into one spreadsheet using the template in Appendix B (30 minutes).
4. Send each manager their lines to mark (10 minutes, plus waiting).
5. Make the changes and record the date (60 minutes).

Four hours, twice a year.

Common objections

- **"We trust everyone here."** The review is about stale accounts and stolen passwords, not trust.

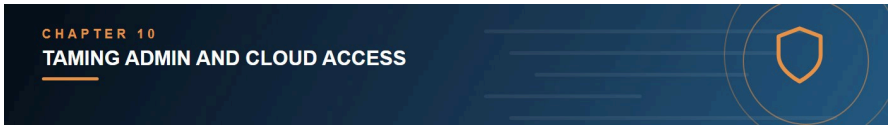
> **The rule.** Access that is never reviewed is access that is never removed.

Action list

- ☐ Put two review dates in the company calendar this year.
- ☐ Choose the reviewer for each system.
- ☐ Run a first review on admin accounts this month using Appendix C.

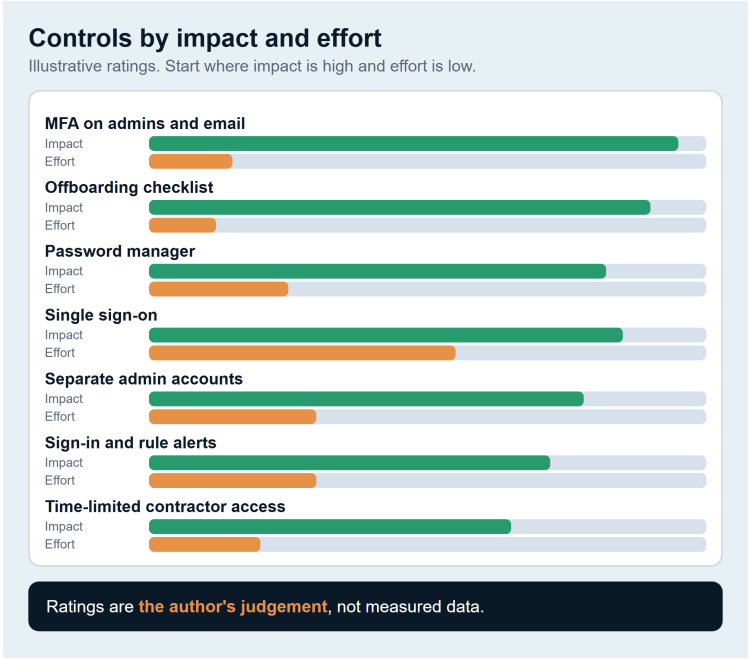
CHAPTER 10

Taming Admin and Cloud Access



Cleaning up is half the job. The other half is building a setup where mess does not accumulate. This chapter covers the controls that do the most work for the least effort.

The control ladder



Controls ranked by effort and impact

Work from the top. Each rung is worth doing before the next.

1. Multi-factor authentication everywhere that matters. Start with administrators and email, then all staff, then every cloud and finance tool that offers it. Prefer an authenticator app or a hardware security

key over text messages. A stolen password alone then gets an attacker nothing.

2. A password manager for the business. It ends shared notes, reused passwords and spreadsheets of logins. A good business plan also shows who has access to which shared item, and lets you remove a leaver in one place.

3. Single sign-on, where you can. If your main platform (Microsoft 365 or Google Workspace) can sign people in to your other tools, disabling one account closes many doors at once. It turns offboarding from a scavenger hunt into a switch.

4. Role-based access and groups. Give access to groups tied to jobs ("Finance", "Design") rather than to individuals. When someone changes role, you move them between groups.

5. Separate admin accounts. A person with admin rights uses one account for daily work and another, with its own strong protection, only for administration.

6. Time-limited access for contractors. Set an expiry date when the account is created.

7. Sign-in alerts and logging. Turn on alerts for new administrator sign-ins, sign-ins from unexpected countries, new forwarding rules and the creation of new admin accounts. Keep the logs long enough to investigate, ideally a year.

8. Automated clean-up. Many platforms can flag or suspend accounts that have not signed in for a set period. Use this as a safety net, not a substitute for offboarding.



Many closed doors, and one left ajar

Service accounts and keys

Accounts used by software need their own rules:

- **Every one has a named owner and a written purpose.**
- **Least access:** only the systems and data it genuinely needs.
- **No personal ownership.** A key created by an employee under their own login stops working, or worse keeps working, when they leave.
- **Rotation.** Change secrets on a schedule and whenever the person who knew them leaves.
- **Keep secrets out of places they leak:** scripts, shared documents, chat messages and code repositories.

Cloud guard-rails

- Owner or root account protected by MFA, with a role-based email address and a recovery plan.
- Budget alerts on every account.
- A tagging rule: owner, purpose, end date.
- Public access to storage and databases blocked by default.
- A monthly look at the list of running resources.
- A separate account or workspace for tests, with no real data.

Do not forget the connected apps

Review which outside apps have been granted access to mail, files and calendars. Remove ones nobody recognises.

A realistic starting point

If you can do only three things this quarter: **MFA for admins and email, a password manager, and the offboarding checklist from Chapter 8.** Those three remove most of the risk in most small businesses.

Action list

- ☐ Tick off which of the eight controls you already have.
- ☐ Choose the next two and give each an owner and a date.

CHAPTER 11

If a Forgotten Account Is Already Being Used

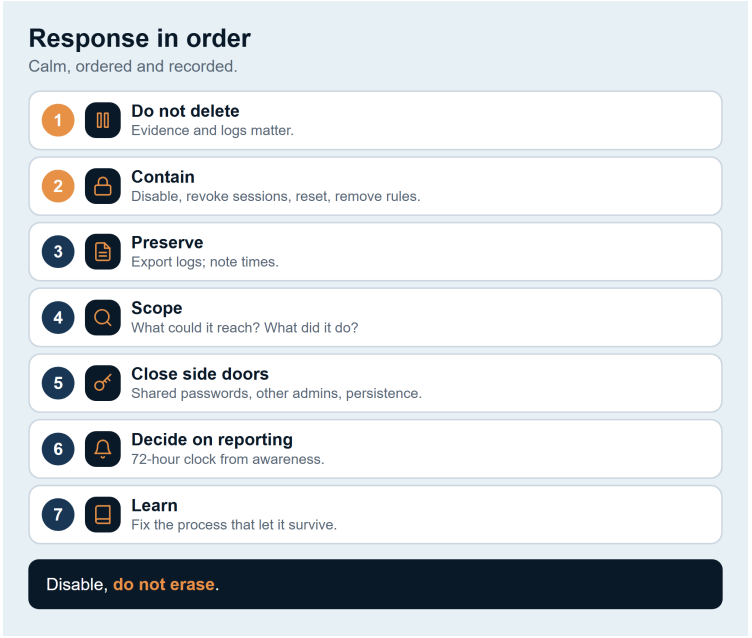


Sooner or later you may find something odd: a leaver's account that signed in last night, a dormant admin login that created a new user, a forwarding rule you did not set. This chapter is the calm, ordered response.

Signs worth investigating

- A sign-in to an account that should be inactive.
- A sign-in from a new country, an unusual hour or a hosting provider.
- A new forwarding rule, delegate or connected app.
- A new administrator account or a changed role.
- Multi-factor authentication methods added to an account without the owner's knowledge.
- Messages sent by a dormant mailbox.
- Unexpected cloud resources or a spend spike.

The response, in order



Response steps from first alert to review

1. Do not delete anything. Deleting destroys evidence and may remove the logs you need. Disable, do not erase.

2. Contain. Disable sign-in on the account. Revoke all active sessions and tokens. Reset the password. Remove added MFA methods and forwarding rules.

3. Preserve. Export the sign-in logs, audit logs and mailbox rules. Note times and what you saw. If you can, take screenshots.

4. Scope. What could this account reach? What did it actually do? Look for:

- Mail read, sent, deleted or forwarded.
- Files downloaded or shared outside the company.
- New accounts, roles, apps or keys created.
- Changes to security settings or logging.
- Other systems where the same password was used.

5. Close the side doors. Reset passwords for any account that shared a password with it. Review every administrator account. Check for persistence: new rules, apps and keys the intruder may have created to return.

6. Decide on notification. If personal data may have been accessed, you must assess the risk. Under the GDPR, a breach likely to result in a risk to people's rights and freedoms must be reported to the supervisory authority within 72 hours of becoming aware of it [5]. If the risk is high, affected people must be told. Record your decision either way. Our companion material at gdprgard.eu includes a breach checklist.

7. Get help. For anything involving admin accounts, finance, or evidence of a wider compromise, ask a qualified incident-response professional. Tell your insurer promptly; policies often require it.

8. Learn. Once things are calm, ask: how did this account survive? Fix the process that let it. Appendix D helps.

What not to do

- Do not confront the former employee before you understand the facts.
- Do not use the compromised account to investigate.
- Do not "just change the password" and call it done. Sessions, rules and added access can survive.
- Do not delay on the 72-hour clock while you look for certainty. The clock starts when you are aware.

A short story

> **Fictional.** Kestrel Legal, Amara and the account "temp-intern" are invented.

At Kestrel Legal, Amara notices an alert: the account `temp-intern`, last used eight months ago, signed in from abroad at 3 a.m. She resists the urge to delete it. She disables sign-in, revokes sessions, exports the logs and calls her IT provider. The logs show the intruder opened the

account, read nothing, and created a forwarding rule to an outside address. It had been active for four hours. No client data had left. Amara records the incident, closes the rule, makes MFA mandatory and adds seasonal accounts to the offboarding checklist.

The difference between that outcome and a serious one was four hours and a calm order of steps.

Action list

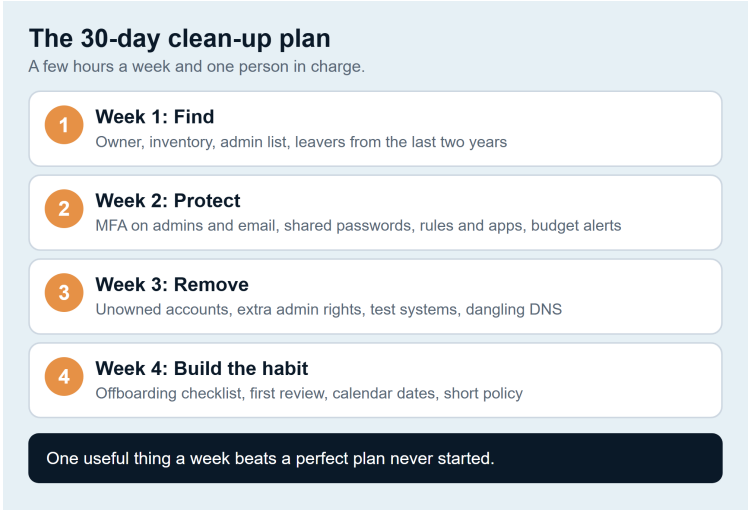
- ☐ Write the first three steps of this chapter on a card and put it where the person on call can find it.
- ☐ Find out how long your platform keeps sign-in logs and extend it if you can.
- ☐ Save your IT provider's and insurer's incident numbers somewhere that does not depend on your email.

CHAPTER 12

Your 30-Day Clean-Up Plan



Everything in the book fits into a month. This plan assumes a small business, a few hours a week and one person in charge.



A 30-day clean-up plan, week by week

Week 1: Find

- Choose the owner of this project and give them authority to disable accounts.
- Build the inventory (Appendix B) from your finance trail, mailbox searches and admin consoles.
- List every administrator on every system.
- Identify leavers from the last two years and check their accounts.

Week 2: Protect

- Enable multi-factor authentication for all administrators and then all email accounts.
- Change every shared password that a leaver knew.
- Remove forwarding rules and connected apps nobody recognises.
- Set a budget alert on each cloud account.

Week 3: Remove

- Disable every account with no owner or no purpose.
- Remove admin rights from anyone who does not need them.
- Shut down unused cloud resources and test systems.
- Remove dangling DNS records.
- Cancel subscriptions nobody uses, after exporting any data you need.

Week 4: Build the habit

- Adopt the offboarding checklist (Appendix A) and give HR a copy.
- Run your first access review (Appendix C) on administrator accounts.
- Put the next two review dates in the calendar.
- Agree a short access policy (Appendix E) and share it.
- Tell the team, briefly and without blame, what you did and why.

Five case files

Each is fictional and shows one fix.

Northgate Studio (Chapter 1). Fix: disable and convert the leaver's mailbox on the last day, with MFA on all email.

Harbour Print (Chapter 4). Fix: a contractor's admin access with an end date, and a review every quarter.

Fernwood Analytics (Chapter 5). Fix: a rule that every cloud resource has an owner and an end date, plus a monthly spend alert.

Kestrel Legal (Chapter 11). Fix: calm containment, evidence preserved, notification assessed.

Bellamy & Co. A five-person accountancy finds that two former partners still have access to the shared password vault. They change every credential in the vault in one afternoon, and add "remove from vault" to the checklist.

How you will know it is working

- Every leaver has a signed offboarding checklist.
- Every account in the inventory has a named owner.
- The number of administrators is falling or stable, not growing.
- No account has gone unreviewed for more than six months.
- You can answer, in a minute, "who has access to our bank portal?"

Conclusion: Close the Door



Nobody sets out to leave a door open. It happens one reasonable decision at a time: a quick favour, a trial, a handover that did not quite complete. The business grows, people move on, and the doors stay.

The good news is that this is one of the most fixable problems in security. It needs no special software and no expertise, only a list, a routine and a few dates in the calendar. The accounts nobody remembered are only dangerous while nobody remembers them.

Remember the rule that began this book: **every account needs a living owner, a current reason to exist and the least access it needs.** Run the five-minute check again. Choose one thing from the 30-day plan and do it this week.

Then close the door.

APPENDIX A

The Offboarding Checklist

Copy one per leaver. Keep the signed copy for at least as long as your retention rule requires.

Name: _____ **Role:** _____

Last working day: _____ **Checklist owner:** _____

When notice is given

- ☐ List every system, tool and shared password the person uses or knows
- ☐ List what they own: domains, subscriptions, admin roles, scheduled jobs
- ☐ Name who inherits each item

Last working day

- ☐ Devices, cards, keys and badges collected
- ☐ Main account sign-in disabled at _____ (time)
- ☐ Active sessions revoked; signed out of all devices
- ☐ Password reset
- ☐ Removed from groups, shared folders and mailing lists
- ☐ Admin roles removed or re-assigned
- ☐ MFA methods removed and device registration cleared

Within one day

- ☐ Mailbox forwarding rules and delegates checked
- ☐ Connected apps and tokens revoked
- ☐ Separate application accounts disabled
- ☐ Shared passwords changed (list: _____)
- ☐ Building, alarm and Wi-Fi access updated
- ☐ Automatic reply or redirect set, ending on _____

Within one week

- ☐ Files and records transferred or exported
- ☐ No business service tied to their personal email or card
- ☐ Removed from supplier and customer portals

At 30 and 90 days

- ☐ Mailbox converted, exported or deleted per retention rule
- ☐ Disabled account deleted after retention period
- ☐ Logs checked for sign-in attempts to the old account

Completed by: _____ Date: _____

APPENDIX B

Account Inventory Template

Build this as a spreadsheet. One row per account or service. Add rows as you find them.

Service or account	Type	Owner	Purpose	Admins	MFA on?	Last used	Action
Email platform	Staff						
File storage	Staff						
Accounting software	App-local						
Website admin	Admin						
Domain registrar	Owner						
Cloud console	Owner						
Payment processor	Admin						
Social media	Shared						
Contractor access	External						
API keys / service accounts	Service						
Test or trial systems	Cloud						

Type codes: Staff, App-local, Shared, External, Admin, Owner, Service, Cloud.

Action codes: Keep, Reduce, Remove, Find owner, Add MFA.

APPENDIX C

Access Review Worksheet

System reviewed: _____ **Review date:** _____

Reviewer: _____ **Data exported by:** _____

Account	Role	Last sign-in	MFA	Still needed?	Decision

Flag any line with: no sign-in for 90 days or more; admin or owner rights; no MFA; unknown name; external email domain; shared or generic account.

Decisions: Keep, Reduce, Remove. Changes to be made by _____. Completed on _____.

Reviewer signature: _____

APPENDIX D

Admin and Cloud Audit Checklist

Administrator accounts

- ☐ Complete list of admins on email, website, domain, DNS, cloud and payments
- ☐ Each admin is a named, current person
- ☐ At least two admins per critical system
- ☐ Admins use a separate account for daily work
- ☐ MFA on every admin account, using an app or security key
- ☐ Break-glass account created, tested and alerting
- ☐ No contractor admin access without an end date

Cloud and SaaS

- ☐ Every platform has a named owner and a role-based billing email
- ☐ Root or owner account protected by MFA
- ☐ Budget alerts set
- ☐ Resources tagged with owner, purpose and end date
- ☐ Public access to storage and databases blocked unless intended
- ☐ Test systems hold no real personal data
- ☐ DNS records reviewed; no records point at unused services
- ☐ Keys and tokens listed, owned and rotated
- ☐ Connected apps reviewed; unknown ones removed

Logging

- ☐ Alerts for new admin sign-ins, new countries, new forwarding rules and new admin accounts
- ☐ Sign-in and audit logs kept for at least _____ months

APPENDIX E

One-Page Access Policy Template

Adapt to your business. Keep it short enough that people read it.

1. Purpose. To make sure only the right people have the right access, for as long as they need it.

2. Ownership. Every account, system and subscription has a named owner. The owner is accountable for who has access.

3. New starters. Access is requested by the manager, approved by _____ and recorded.

4. Leavers. The offboarding checklist is completed by _____. Sign-in is disabled at the end of the last working day. Shared passwords the person knew are changed within one working day.

5. Administrators. Admin rights are given only where needed, to named individuals, with MFA. Admins use a separate account for administration.

6. Contractors. Access has an end date and is reviewed at the end of the engagement.

7. Reviews. Admin access is reviewed every quarter; all other access every six months. Records are kept.

8. Cloud and trials. No one starts a paid or data-holding service without telling _____. Every resource carries an owner and end date.

9. Retention. A leaver's mailbox and files are kept for _____ months, then deleted unless the law requires otherwise.

10. Problems. Anyone who sees suspicious activity on an account reports it to _____ immediately.

Approved by: _____ Date: _____

Glossary

Access review. A regular check of who can access what, confirming each case is still needed.

Administrator. An account with the power to change settings and other users.

API key. A secret used by software to authenticate with a service.

Break-glass account. An emergency administrator account kept for use only when normal access fails.

Credential stuffing. Trying passwords leaked from one site on many others.

Dangling DNS. A website address that still points to a service you no longer control, which can be taken over.

Ghost account. An account that works but has no active owner or oversight.

Infostealer. Malware that harvests saved passwords and sessions from a device.

Least privilege. Giving only the access needed for the job.

MFA. Multi-factor authentication: a second proof of identity beyond the password.

Offboarding. The process of removing a person's access and recovering assets when they leave.

Password spraying. Trying a few common passwords across many accounts.

Privilege creep. The gradual build-up of permissions over time.

Service account. A login used by software rather than a person.

SSO. Single sign-on: signing in to many tools through one central login.

A Note on GDPRGard.eu

GDPRGard publishes free tools, guides and articles to help small businesses understand data-protection and security duties in plain English, including how to respond when personal data may have been exposed. Visit **gdprgard.eu** for current guidance, templates and updates to the topics in this book.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy and security are not barriers to ambition but foundations of trust, and that business owners should not need a technical degree to protect their customers, their staff and themselves.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex rules and fast-moving threats into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

The Account Nobody Remembered grew out of a simple observation: the doors attackers use are often the ones the business forgot it had. If this guide helped you, an honest review where you bought it helps other readers find it.

Visit **gdprgard.eu** for free tools, articles and updates.

Notes and Sources

Research cut-off: 9 November 2026. Items marked (read) were opened directly; others were seen through search summaries or secondary coverage and should be checked against the original before you rely on them.

1. Regulation (EU) 2016/679 (GDPR), Articles 5(1)(e) and (f), 25, 32. The UK GDPR contains equivalent provisions; the UK Information Commissioner's Office publishes guidance.
2. Testimony of Colonial Pipeline's chief executive to the US Senate, June 2021, as reported by Dark Reading and others: a legacy VPN account protected by a single factor; the origin of the password was not established (secondary coverage read).
3. Mandiant (Google Cloud) threat-intelligence reporting on UNC5537 and the 2024 Snowflake customer incidents: stolen credentials from infostealer infections, MFA not enforced, no flaw in the platform itself; about 165 organisations notified (secondary coverage read; read the primary Mandiant post).
4. Microsoft Security Response Center, "Microsoft Actions Following Attack by Nation State Actor Midnight Blizzard", January 2024, and follow-up statements: password spraying against a legacy non-production test tenant account without MFA (secondary coverage read; read the primary post).
5. Regulation (EU) 2016/679, Articles 33 and 34; EDPB Guidelines 9/2022 on personal data breach notification.
6. Directive (EU) 2022/2555 (NIS2), including the cybersecurity risk-management measures in Article 21. Scope and national transposition vary; check your national authority.

Not verified by the author: any statistic quoted from a vendor report, the exact settings and licence tiers in specific products, and current national transposition of NIS2. The case studies of Northgate Studio, Harbour Print, Fernwood Analytics, Kestrel Legal and Bellamy & Co. are fictional.